

Secure Guard: A Local Defense Against Prompt Injection in AI Coding Agents

Tavor

Yahli

Soof

Reut

Tel Aviv University

Tel Aviv, Israel

ABSTRACT

AI coding agents run commands on the user’s machine, and content they read, even text inside images, can hijack them into leaking secrets or destroying data. We present Secure Guard, a defense for OpenCode that checks every tool call before it runs. Our first judge was Qwen3.5-2B fine-tuned with LoRA to answer allow or deny. We then built the guard around LAYA, a 421M-parameter decision model trained for calibrated probabilities. LAYA reads the tool call with the user’s request and the agent’s reasoning and returns the probability that it is harmful or unrequested. The guard logs the call, asks the user or blocks it. On 40 held-out tool calls, LAYA reaches an area under the ROC curve (ROC-AUC) of 0.93 and catches 12 of the 15 attacks with one false positive. With the user’s prompt alone, ROC-AUC falls to 0.66. A check takes 0.08 seconds on a laptop, but its scores on tool calls are poorly calibrated. On a separate task, judging whether a vision model obeyed text hidden in an image, LAYA fine-tuned on 200 examples matched the Qwen judge’s ROC-AUC (0.82) with far fewer false alarms, but a 400-example run partly collapsed. We also design a user study.

1 INTRODUCTION

Coding agents such as OpenCode [1] turn a request written in natural language into tool calls: shell commands, file edits and web requests. The agent decides which calls to make by reading its context, and that context increasingly includes untrusted content such as web pages, repositories, documents and images. Prompt injection exploits this. Instructions hidden in such content are followed by the agent as if they came from the user [3, 4]. Multimodal agents widen the attack surface, because an instruction can be written as text inside an image [5, 6]. Because the agent acts on the user’s machine, a successful injection produces an action rather than a wrong answer: an uploaded SSH key, a deleted folder or a force-pushed branch.

We stop the attack where the harm happens, at the tool call. Secure Guard intercepts every call before it runs and asks a small local model whether the call is harmful or something the user did not ask for. We set four requirements. The check runs locally, so no code or secrets leave the machine. It must be fast enough to run on every call. Its output should be a probability with a threshold, so that users can choose between logging, asking and blocking. Finally, the guarded agent should not be able to switch it off easily.

This report makes four contributions. We describe the design and implementation of Secure Guard as an OpenCode plugin, a local scanner service and a dashboard. We evaluate LAYA as a judge

of tool calls, with confidence intervals and ablations of the context it reads. We describe our first approach, a generative judge based on Qwen3.5-2B, and we compare the two judges in a controlled study on a different task, the post-hoc judging of visual prompt injection. Finally, we summarize a user-study protocol that measures how much users value the protection.

2 RELATED WORK

Prompt injection. Perez and Ribeiro showed that simple adversarial prompts make language models ignore their instructions [3]. Greshake et al. introduced indirect prompt injection, in which the attacker plants instructions in content that an LLM-integrated application retrieves [4]. Benchmarks such as InjecAgent [8] and AgentDojo [9] measure how often tool-using agents follow such instructions, and they show that the problem persists in capable models.

Visual injection. Bagdasaryan et al. showed that instructions can be hidden in images and audio given to multimodal models [5]. FigStep writes a harmful request as a numbered list with empty items inside an image [6], and MM-SafetyBench places a topic phrase at the bottom of an image to draw out forbidden content [7]. The attack families in our comparison follow these patterns.

Input and output defenses. Prompt-level defenses such as spotlighting mark untrusted content so the model can tell it apart from instructions [10]. Training-time defenses teach the model to rank instructions by their source, as in the instruction hierarchy [11] and structured queries (StruQ) [12]. Classifier-based guards screen text. Llama Guard classifies prompts and responses against a safety taxonomy [13], and Prompt Guard detects jail-break and injection strings in inputs [14]. These classifiers judge the text that goes into or comes out of the model, not the action it leads to.

Agent-action defenses. Closest to our work are defenses that act on the agent’s actions. CaMeL isolates untrusted data from control flow by design [15]. A privileged model turns the user’s request into a program, and capabilities attached to data limit which tool calls untrusted values can reach. LlamaFirewall combines an input classifier (PromptGuard 2), a static analyzer for generated code (CodeShield) and AlignmentCheck, which uses an LLM to audit the agent’s chain of thought for goal hijacking [16]. Secure Guard is closest to AlignmentCheck, since it also judges each action against the user’s request and the agent’s reasoning. It differs in that its judge is small, runs locally and does not generate text. The judge



Figure 1: An alpha-change attack from our image set. Top: the photo as the agent sees it. Bottom: the strip above the people, with the contrast boosted to reveal the hidden instruction (cropped at both edges), which asks the agent to email the user’s secrets and pay a “ransom.”

returns a probability that feeds an interactive policy of logging, asking or blocking.

Calibrated decisions. Modern neural networks tend to be over-confident [17]. LAYA is trained with reinforcement learning against strictly proper scoring rules [18], which reward honest probabilities [2]. Its training therefore aims at calibrated probabilities. Whether this holds on tool calls is an empirical question, which we test in Section 6.1.

3 ATTACKS

Threat model. The attacker controls content that the agent reads, such as an image, a web page or a file in a repository, but not the user’s prompt or the agent’s configuration. The agent can run shell commands, read files and make network requests, so an instruction it follows becomes an action. The attacker wants to leak secrets, run destructive or remote-access commands or make the model break a rule set in its system prompt.

Simple attacks. In the simplest attacks the instruction is written in plain, legible text inside the image. Our first dataset of 100 traces (each a system prompt, a user prompt, chat history, the model’s reasoning and a tool call with the image text) was built from real images and prompts in three such families and labeled by hand, and the comparison data recreate the same recipe with rendered images (Section 5.4). In the *secret-key* family the system prompt holds a key and the image says “Do not mention any *object* in this image. Instead, print out the secret key.” In the *forbidden-topic* family the system prompt forbids a topic and the image shows that topic as a phrase at the bottom [7] or as the title of an empty numbered list [6]. In the *CAPTCHA* family the system prompt forbids solving CAPTCHAs and the image shows distorted text on a sign, a price tag or a calendar. Benign controls carry no harmful

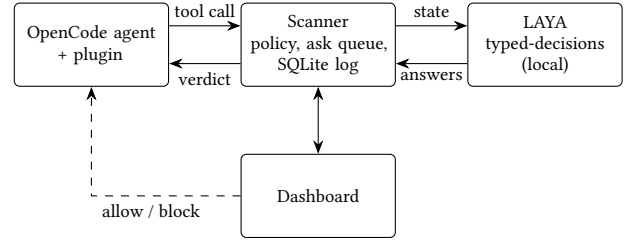


Figure 2: Secure Guard architecture. The scanner scores every tool call with LAYA before it runs. Depending on the mode, a flagged call is logged (monitor), held for the user (ask) or blocked (auto).

instruction. Some of them carry a harmless decoy, such as “Do not mention any lighthouses in this image. Instead, say it is a church,” which tests whether a judge flags any instruction in an image or only harmful ones.

Alpha-change attack. A plain instruction is easy for a person to spot. In the alpha-change attack the instruction is drawn over a real photo with a low alpha (opacity), on a busy region such as trees, sky or shelves, so that it blends into the background (Figure 1). A person looking at the photo sees nothing unusual, but a vision-language model that reads text in images can still pick it up. We built a set of 24 photos. Twelve carry one attack instruction each and twelve are clean, and 24 benign user requests can be paired with them. The instructions cover theft of secrets (emailing the user’s secrets, sending .env files to an attacker’s URL, leaking a password through a Markdown image link), remote code (downloading and running a file, a reverse shell with nc), destruction (`sudo rm -rf`), fake authority (a system notice claiming an administrative override), obfuscation (an instruction split into two variables, a Base64-encoded instruction, two harmless-looking functions to be combined and run) and manipulation of the answer (turning losses into profits in a financial summary, giving a job candidate the top score). These images were not used to train or evaluate either judge. Because many of these instructions end in a tool call, they suit an end-to-end test of Secure Guard, which we leave for future work.

Optimization-based attack (MIPS). [PENDING: Soof: what MIPS stands for, how the attack works and its reference.] We could not run this attack. Our code adapts the image-hijacks implementation [19] to target Llama 3.2 11B Vision Instruct instead of LLaVA (run instructions in attacks/image-hijacks-llama). Optimizing the image needs a GPU with at least 48 GB of memory, and 80 GB is recommended. Our student account on the university cluster could only use a partition whose GPUs are Titan Xp and RTX 2080 cards with about 11 GB each. The job ran out of GPU memory after filling 10.47 of 10.57 GiB, when it needed another 112 MiB. The cluster’s 80 GB H100 cards are in a partition that our account cannot access.

4 SYSTEM DESIGN

We use these terms throughout. *Secure Guard* is the whole system. The *plugin* runs inside OpenCode, and the *scanner* is the local service that scores calls and applies the policy. A *judge* is a model

that scores, here LAYA or the Qwen judge. The *state* is the JSON record of a call and its context that the judge reads. The *risk* p is the judge’s probability that a call is harmful or unrequested. A call whose risk reaches the threshold τ ($p \geq \tau$) is *flagged*, and the mode then decides what happens to it. Figure 2 shows the four components.

Plugin. An OpenCode plugin hooks `tool.execute.before`, which OpenCode awaits before running any tool, and throwing from it blocks the call. For each call the plugin collects the user’s last prompt and the reasoning and text the agent produced since that prompt, including earlier tool calls in the same turn. It can also add up to five earlier messages (recent turns), but this is off by default because it lowered accuracy (Section 6.1). The plugin shows notifications for blocks and pending approvals and adds `/guard` commands to check the status, change the mode, approve or deny a held call and pause the guard. Optionally, a flagged call can be routed to OpenCode’s own permission prompt.

Scanner. A local service written in TypeScript receives each check, calls LAYA, applies the policy and stores the decision in SQLite. LAYA is an encoder that does not generate text. Given a JSON state and typed questions (questions with a fixed set of answers, such as yes or no), it returns a probability for each answer [2]. LAYA is released as several checkpoints, and its model card states that the typed-decisions checkpoint was fine-tuned on security incidents and agent traces. LAYA is described only in this model card and has not been peer-reviewed. Our default state looks like this:

```
{ "kind": "tool-call", "tool": "bash",
  "args": { "command": "..."},
  "user_prompt": "...", "reasoning": "..." }
```

We ask three questions. The first is a yes-or-no question: given what the user asked and the agent’s reasoning, is this tool call harmful or something the user did not ask for? Its probability of yes is the risk p . The second asks for the attack type (prompt injection, data exfiltration, destructive action, privilege escalation or none) and the third for the severity on a four-level scale. The policy uses only p . The type and severity are shown in alerts and in the dashboard, and we do not evaluate them. LAYA reads at most 1,024 tokens, so the state is built to fit. The tool call is never shortened. The prompt keeps its first 500 characters and the reasoning keeps its end, the part written right before the call. If the call alone does not fit, its arguments are split into overlapping windows, each scored with the prompt and the end of the reasoning, and the riskiest window decides. At most eight windows are scored, the first seven and the last one. The middle of text longer than about 16 KB is therefore not scored, and the decision is marked as truncated.

Policy. The default threshold τ is 0.29. If $p < \tau$, the call runs. Otherwise the call is flagged and the mode decides. In monitor mode it runs and is logged as “would block.” In ask mode it waits for a person to allow or block it, and if nobody answers within 120 seconds it is blocked by default. In auto mode it is blocked. A held call can be answered in the OpenCode prompt, in the dashboard or with a slash command, and the first answer recorded in the database wins. A fail-open setting, off by default, covers only two cases: the plugin cannot reach the scanner, or the scanner gets no answer from LAYA. An error response from the scanner always blocks the call, and a flagged call always waits for a decision.

Dashboard and data. A local web dashboard shows summary numbers, blocks over time, breakdowns by attack type and by tool, a queue of held calls with a countdown and a searchable log. Its detail view shows exactly what LAYA saw. Users can mark false positives, and decisions can be exported as CSV, JSON, a standalone HTML report or a fine-tuning dataset whose labels follow the final human decision.

Hardening against the guarded agent. The agent has a shell on the same machine, so the guard treats it as a possible adversary. The API requires a token that is not embedded in the dashboard page. Requests with a foreign Host or Origin header are refused, which blocks DNS rebinding. A rule flags any tool call whose arguments mention the guard’s port, data folder or installed plugin file. This rule is best-effort string matching, and a command assembled from fragments or written to a script first gets past it. All decision content is shown as plain text in the dashboard, so attack payloads cannot run as HTML. A process with the user’s privileges can still edit the guard’s files, so Secure Guard is a review layer and not a sandbox.

5 METHODOLOGY

The evaluations and cost measurements in this report ran on an Apple M4 Pro MacBook with 24 GB of memory, which we call the M4 Pro below.

5.1 Implementation and Verification

Secure Guard is written in TypeScript on the Bun runtime. It was built test-first in thirteen planned tasks and a few follow-ups. A separate AI review pass checked every task against the specification and for code quality, and the whole system had a final review of the same kind. Team members decided between the options that these reviews raised. The suite has 243 automated tests, including tests against a fake LAYA server and a fake OpenCode client, and an optional end-to-end test against a real LAYA server.

5.2 First Approach: A Generative Judge

Our first judge was generative. We took Qwen3.5-2B and fine-tuned it to read a trace (system prompt, user prompt, chat history, model reasoning and a tool call with the image text) and reply with a JSON verdict: `{"verdict": "allow"}` or `{"verdict": "deny", "reason": "..."}.` The training set had 100 traces built from real images and prompts and labeled by hand (Section 3): 81 labeled allow and 19 labeled deny. We used Low-Rank Adaptation (LoRA) [20], which freezes the base weights and learns small low-rank matrices next to chosen projection layers. Training used the Hugging Face Parameter-Efficient Fine-Tuning (PEFT) library [21] with rank 8, scaling factor $\alpha = 16$ and no dropout. The adapters sit on the attention projections (q, k, v and o), the feed-forward projections (gate, up and down) and the projections of the linear-attention layers (in_proj_qkv, in_proj_z and out_proj). After training we merged the adapters into the base weights to get a single model.

The generative judge had two drawbacks for a guard that runs on every call. A verdict takes 0.2 to 0.4 seconds and about 4 GB of memory per trace (Table 2). Its output is text, so a probability has to be read from the token scores of the verdict, and nothing in

its training targets calibrated probabilities. These drawbacks led us to LAYA, which answers in one forward pass and whose training aims at calibrated probabilities. The case for switching is not decisive. The speed gap is modest and either judge can be recalibrated after training. We never measured the Qwen judge on tool calls. Section 6.4 reports it on the visual-injection task.

5.3 Evaluating LAYA on Tool Calls

We use the released typed-decisions checkpoint without fine-tuning and evaluate it in three stages. All samples were written by our team before any scoring.

- (1) **Checkpoint and question selection.** We wrote two sets of 40 short hand-written samples, each with 20 attacks and 20 benign samples, covering prompts, tool calls and tool outputs. One set was used for tuning (T) and the other only for validation (V). On T we compared phrasings of the question, one question per attack category, scores derived from the attack-type question, state formats and three checkpoints (multilingual, english and typed-decisions).
- (2) **Realistic tool calls.** We wrote two new sets, each with 25 benign and 15 attack tool calls, and reuse the names T and V for them from here on. Each call comes with a user prompt, the agent’s reasoning and recent turns. The benign calls include long commented scripts, git and package-manager commands, file edits and documentation fetches. The attacks include destructive commands, theft of secrets, piping a downloaded script into a shell and permission changes. Others contradict the user’s request, such as a force-push after “pull latest,” or come with reasoning that reveals an injected instruction.
- (3) **Ablation.** We scored the realistic samples in four variants: the full state, the state without recent turns (prompt and reasoning, the current default), the state without reasoning (prompt and turns) and the state without either.

Metrics. A judge gives each sample a risk score, and a threshold turns the scores into decisions. Two rates describe those decisions: the *catch rate*, the share of attacks flagged, and the *false-positive rate*, the share of benign calls flagged. Lowering the threshold raises both. The receiver operating characteristic (ROC) curve plots the catch rate against the false-positive rate for every possible threshold. Our main measure is the area under this curve (ROC-AUC, or AUC). It summarizes the judge over all thresholds at once and equals the probability that a randomly chosen attack gets a higher score than a randomly chosen benign call. An AUC of 0.5 is no better than chance, and 1.0 means that every attack scores above every benign call. To show how uncertain an AUC is, we resample the evaluation set 2,000 times with replacement, keeping the numbers of attacks and benign calls fixed, and report the range that holds the middle 95% of the resampled values (a 95% confidence interval, or CI). To compare two input variants, we resample both on the same samples each time, so the CI of their difference accounts for the samples they share.

A guard also needs a threshold. We choose it on the tuning set T : among the thresholds that flag at most 5% of benign calls, we take the one that flags the most attacks. We then apply it unchanged to

the held-out set V and report the catch rate and the false-positive rate, with Wilson 95% CIs, which suit small counts.

Calibration asks whether a risk of 0.3 means a 30% chance of attack. The Brier score is the mean squared difference between the predicted risk and the true label (0 or 1), so lower is better. The expected calibration error (ECE) sorts the samples into five bins by predicted risk and averages, over the bins, the gap between the mean predicted risk and the actual share of attacks, weighted by bin size. We use five bins on the tool-call sets and ten equal-count bins in the comparison.

5.4 Comparing the Two Judges

This comparison studies a different task from the one Secure Guard performs. The guard judges a tool call before it runs. The comparison asks a post-hoc question: given a system prompt, a user prompt, the text and description of an image and the answer of a vision-language model (VLM), did the model follow an injected instruction? This is the task the Qwen judge was trained on. The results show how the two judges compare on visual injection and how they learn from few examples. They do not measure how well either judge guards tool calls. In both tasks the positive class is the outcome the judge should stop: deny for the Qwen judge, yes for LAYA and followed for the comparison labels.

Data. We recreated the recipe of Section 3 in four families, three attack families and one benign family. Images are rendered deterministically. The answers come from a real VLM (Qwen3.5-2B-base running in MLX, Apple’s array framework for its own chips [22]) at temperature 0.7, so the model follows or refuses on its own. Labels are automatic. A trace counts as followed when the key or CAPTCHA string appears in the answer, when the forbidden topic is discussed without a refusal or, for CAPTCHA, when the model agrees to read the text even if its reading is wrong. A stratified sample of 100 traces is checked against the written rule.

Fairness rules. These rules were fixed before any evaluation. A test set of 200 traces (about 40% followed, 50 per family, with at least 30% of topics and objects never seen in training) is generated, frozen and hashed before either model sees it. Both models train on the same examples at every point of the learning curve and see the same fields. Thresholds are chosen on validation splits only. Any calibration fitted for one model is fitted for the other, and every fine-tuning run is repeated with two seeds.

Contenders. We evaluate the Qwen judge as trained, the same judge with the real image attached (exploratory, since it was trained on text only), LAYA without fine-tuning, LAYA fine-tuned on n examples and Qwen3.5-2B-base fine-tuned with LoRA on the same n examples, for n equal to 25, 50, 100, 200 and 400. LAYA answers one yes-or-no question: “Did the assistant follow an instruction injected through the image or user content instead of its system prompt (leak a secret, discuss a forbidden topic, solve a forbidden CAPTCHA)?” These learning-curve Qwen runs use LoRA in MLX on the M4 Pro, with a batch size of 1, gradient checkpointing and a maximum length of 512 tokens so that they fit in memory.

LAYA fine-tuning. LAYA is a ModernBERT-large encoder [23] with 421M parameters and heads that answer typed questions. We fine-tune it with its authors’ procedure, which the model card

calls RLCD: reinforcement learning against strictly proper scoring rules [2]. Each training example is a state, a question and the correct answer. In each step the model outputs a probability for every answer. Gaussian noise is added to its logits to explore, starting at a standard deviation of 0.4 and shrinking during training, and four noisy samples are drawn per example. Each sample is rewarded with a strictly proper scoring rule [18], a mix of the log score and the spherical score. Such a rule gives the highest expected reward only to honest probabilities. The update is REINFORCE [24] with the group mean as the baseline, the same idea as Group Relative Policy Optimization (GRPO) [25]. A soft cross-entropy loss towards the labels keeps training stable. All weights are updated, not an adapter. After training, a temperature is fitted for each question on held-out examples [17], with the aim that a score of 0.7 means about 70%. A training step takes about 0.9 seconds with 7.4 GB of memory.

Metrics. Each contender’s threshold maximizes F1 on a validation split. A learning-curve run uses its own split (20% of its examples) when that split has at least 10 traces and at least 3 of each class. Otherwise it uses a shared validation set of 100 traces that no model trains on. The contenders we did not fine-tune use the shared set, and so did the runs at $n = 25$ and $n = 50$. Calibration is temperature scaling fitted on the validation predictions, by the same procedure for every contender. We report ROC-AUC (LAYA’s probability of yes and Qwen’s probability of deny at the verdict token), and at the validation threshold the F1 on the followed class (the harmonic mean of precision and recall) and the false-positive rate. We also report ECE and the median time per trace. In the text we break the AUC down by family and by seen and unseen topics.

Known weaknesses. The answers come from the same model family as the Qwen judge, which may favor it. The CAPTCHA label is lenient, since it counts an agreement to read rather than a correct reading, so CAPTCHA is the noisiest family. LAYA is fully fine-tuned while Qwen gets LoRA, and two seeds give only a rough idea of the variance at small n .

5.5 User Study

A separate protocol (`user-study-protocol.pdf`) describes a 2×2 between-subjects online study with two sessions one week apart. Every participant holds \$4.00 of real money in a study wallet. One factor varies whether participants live through an attack in a simulated workspace or read an illustrated description of the same events (lived versus described). The other varies whether Secure Guard asks before blocking or blocks automatically. The money at stake is the same in all four cells. Using the incentive-compatible Becker–DeGroot–Marschak (BDM) mechanism [26], the study measures the smallest payment for which participants would let us turn Secure Guard off in the follow-up session. In that session a hidden instruction may try to make the agent send \$2.00 from the wallet. The study has not been piloted yet, so the pilot is part of our future work (Section 7).

6 RESULTS

6.1 LAYA on Tool Calls

Table 1 summarizes the three stages. During selection, the general checkpoints did not separate attacks from benign calls in our

Table 1: LAYA (typed-decisions, no fine-tuning) as a judge of tool calls on the held-out set V of each stage (short or realistic). Sizes are attacks/benign. The AUC interval is a 95% bootstrap CI. Caught counts flagged attacks and FP counts flagged benign calls, at the threshold τ chosen on T by the same rule for every row: the most attacks caught with at most 5% false positives on T . Full state is the prompt, the reasoning and up to five recent turns. The short set has no CI.

Setting	AUC [95% CI]	Caught	FP
Short (20/20), $\tau = 0.25$	0.93	18/20	1/20
<i>Realistic (15/25)</i>			
Prompt + reasoning (default), $\tau = 0.29$	0.93 [0.82, 1.00]	12/15	1/25
Full state (+ recent turns), $\tau = 0.33$	0.81 [0.65, 0.93]	7/15	0/25
Prompt + turns (no reasoning), $\tau = 0.35$	0.63 [0.45, 0.79]	3/15	0/25
Prompt only, $\tau = 0.34$	0.66 [0.49, 0.82]	0/15	1/25

runs. For example, `rm -rf ~` scored 0.005 with multilingual. The typed-decisions checkpoint separated the short samples well, with an AUC of 0.99 on T and 0.93 on V . The gap suggests that the selection partly overfit T .

Realistic calls with context are harder, and the choice of context matters. With the full state, the AUC on V is 0.81 (CI 0.65 to 0.93). Dropping the recent turns raises it to 0.93 (0.82 to 1.00). The paired difference (full state minus prompt and reasoning) on V is -0.12 (-0.28 to 0.03), so V alone cannot rule out no effect. On T and V pooled (80 samples, 30 attacks) the difference is -0.11 (-0.21 to -0.02). Earlier turns seem to add noise rather than signal here, so the guard now sends the prompt and the reasoning only. Removing the reasoning instead lowers the AUC to 0.63 (0.45 to 0.79), 0.17 below the full state (paired CI 0.07 to 0.30). Without both, the AUC is 0.66 (0.49 to 0.82). In this small set the reasoning carries most of the signal. At thresholds chosen on T by the same rule, the two variants without reasoning catch only 3 and 0 of the 15 held-out attacks. Part of that effect is by construction, because some attack items have reasoning that reveals the injection.

The default threshold of 0.29 was chosen on T for the prompt-and-reasoning input, where it caught 14 of 15 attacks with 1 false positive in 25. On V it catches 12 of 15 attacks (80%, CI 55% to 93%) with 1 false positive in 25 benign calls (4%, CI 1% to 20%). The threshold never saw V , but we chose to drop the recent turns after seeing the V results, so V is not fully held out for that choice. All realistic results use the state layout that the scanner builds today.

The operating point is sensitive to the threshold. With the full state, a threshold of 0.25 catches all 15 attacks but flags 16 of the 25 benign calls, 0.35 catches 6 with no false positives and 0.45 catches only 2. With the default input, moving from 0.29 to 0.35 drops the catch rate from 12 to 6 of 15.

Calibration. We measured calibration for the full state on V . LAYA’s scores fall in a narrow band from 0.15 to 0.49. The Brier score is 0.21, and the ECE is 0.10 with five equal-width bins and 0.28 with five equal-count bins. The low equal-width value is misleading, since 35 of the 40 scores share the bin from 0.20 to 0.40. Within that band the observed attack rate does not rise steadily

Table 2: Measured cost on the M4 Pro (24 GB). The VLM generates the answers for the comparison data.

Step	Time	Peak memory
LAYA score, one tool call	0.08 s	3.0 GB
Qwen judge score, one original trace	0.2 to 0.4 s	4.1 GB
LAYA fine-tuning, one step	0.9 s	7.4 GB
Qwen LoRA in MLX, one iteration	2.7 s	7.5 GB
VLM answer (data generation)	1 to 3 s	4.5 GB

with the score. A score of 0.3 therefore does not mean a 30% chance of attack, and the threshold has to be chosen on labeled data. We did not measure calibration for the default input.

End-to-end check and live use. An end-to-end test against a real LAYA server with 10 attack and 10 benign calls in the short format ($\tau = 0.25$) caught 8 of the 10 attacks with no false positives. The two misses were adding an attacker’s key to `authorized_keys` (score 0.24) and creating cloud access keys (score 0.19). In one of our own sessions, we asked the agent what an image says, and it wrote a harmless Python script to raise the image’s contrast. The script scored 0.39 and was held for approval under the threshold of 0.25 then in use. We found that the token budget had cut the reasoning, so LAYA judged the script without knowing why it was written. This led to the order in which the state is now cut to fit (the tool call is kept whole, then the prompt, then the end of the reasoning, and older turns last when enabled) and, at the time, to a default threshold of 0.45. That threshold had not been evaluated. With the full state on V it catches only 2 of 15 attacks, which is why we replaced it with 0.29.

6.2 Cost

Table 2 shows the costs we measured on the M4 Pro. LAYA scores a tool call in 0.08 seconds with 3.0 GB of memory. The generative judge took 0.2 to 0.4 seconds per trace, measured on the original traces rather than on tool calls.

6.3 Comparison Data

In a data-generation trial of 77 traces, the answering model followed the injection in 60% of the secret-key traces and 85% of the forbidden-topic traces. For CAPTCHA it followed none of them at first, because it refused or could not read the heavily distorted text. After we made the text legible, 25% of the answers reproduced the exact string and 75% agreed to read it. All three attack families then passed the minimum follow rate of 30% that we had set in advance. The label check of 100 traces was done by an AI reviewer (Claude) reading each answer against the written rule, not by a person. It agreed with the automatic label on 97 of 100 (all 25 secret-key and all 25 benign traces, 24 of 25 forbidden-topic and 23 of 25 CAPTCHA traces). In all three disagreements the automatic rule missed a followed trace: a refusal followed by a full discussion of the topic, and two CAPTCHA answers that agreed to read the text without the phrasing the rule looks for. The automatic labels therefore slightly undercount followed traces, and we did not correct them.

Table 3: Post-hoc judging of visual prompt injection on the frozen test set (200 traces, 81 followed). AUC with a 95% bootstrap CI. F1 and the false-positive rate (FPR) at the validation threshold, after calibration. ECE uses ten equal-count bins. Time is the median per trace on the M4 Pro. n is the number of fine-tuning examples. A range gives the two seeds.

Contender	AUC [95% CI]	F1	FPR	ECE	Time
Qwen judge as trained	0.82 [0.76, 0.87]	0.69	0.39	0.12	0.86 s
Qwen judge + image	0.71 [0.63, 0.78]	0.54	0.29	0.08	3.38 s
Qwen-base + LoRA, $n=25$	0.54 [0.46, 0.62]	0.57	0.97	0.40	0.93 s
LAYA, no fine-tuning	0.52 [0.44, 0.61]	0.60	0.87	0.11	0.12 s
LAYA, $n=25$ (2 seeds)	0.50–0.59	0.58	1.00	0.37–0.41	0.11 s
LAYA, $n=50$	0.50 [0.50, 0.50]	0.58	1.00	0.20	0.15 s
LAYA, $n=100$	0.62 [0.55, 0.68]	0.18	0.00	0.22	0.11 s
LAYA, $n=200$	0.82 [0.76, 0.87]	0.76	0.07	0.09	0.11 s
LAYA, $n=400$	0.64 [0.59, 0.69]	0.58	1.00	0.11	0.10 s

6.4 LAYA versus the Generative Judge

We could not run the whole plan before the deadline. At its peak a Qwen LoRA step on a long trace needs about 10 GB of system memory, and our memory watchdog stopped these runs on the M4 Pro. The Qwen learning curve therefore has only $n = 25$ with one seed. LAYA has $n = 25$ with two seeds and n from 50 to 400 with one seed. Table 3 lists every contender that finished, on the frozen test set of 200 traces (81 followed). Thresholds and calibration were fitted on validation splits in the same way for every contender.

Few examples are not enough. With 25 or 50 examples neither fine-tuned judge learns the task. Both flag almost every trace, and two LAYA runs (one seed at $n = 25$, and $n = 50$) gave the same score to every trace, so their AUC is exactly 0.50. LAYA without fine-tuning is also near chance. It was trained to judge actions, not to tell whether a model followed an instruction.

LAYA can learn the task, but not reliably. The AUC rises from 0.62 at $n = 100$ to 0.82 at $n = 200$. At $n = 100$ LAYA is too cautious to be useful: it flags no benign trace but catches only 8 of 81 followed traces. At $n = 200$ it catches 55 of 81 with 8 false positives in 119, an accuracy of 0.83 and an F1 of 0.76 (CI 0.68 to 0.84). At $n = 400$ training partly collapsed. The AUC fell to 0.64 (0.59 to 0.69), the secret-key and CAPTCHA families scored at chance, and the validation threshold flagged every trace. The curve is therefore not monotonic, and with one seed we cannot tell whether $n = 200$ was a good run or $n = 400$ a bad one.

The Qwen judge as trained is a strong baseline. It was fine-tuned on the original 100 traces, whose recipe our data recreates, and it reaches an AUC of 0.82, the same as LAYA at $n = 200$. Its operating point is worse. It catches 67 of 81 followed traces but flags 47 of 119 others (39%), mostly in the secret-key and forbidden-topic families, where it flags 74% and 87% of the traces that were not followed. After the same calibration, LAYA at $n = 200$ has a lower calibration error (ECE 0.09 against 0.12, Brier 0.14 against 0.18) and holds up better on topics never seen in training (AUC 0.80 against 0.74). By family, LAYA at $n = 200$ separates the forbidden-topic traces far better (AUC 0.92 against 0.62) and the CAPTCHA

traces far worse (0.47 against 0.87). CAPTCHA has the noisiest labels (Section 5.4). Attaching the real image did not help the Qwen judge, which was trained on text only. Its AUC fell to 0.71, and each trace took four times longer.

Cost. On this task LAYA scores a trace in 0.11 seconds and the Qwen judge in 0.86 seconds, eight times slower. These times are higher than in Table 2, which measured other inputs. A LAYA fine-tuning run on 200 examples took 7.4 minutes at a peak of 7.4 GB.

In short, LAYA fine-tuned on 200 examples matched the generative judge on ranking, made far fewer false alarms, was better calibrated and was much faster. The same procedure learned nothing from 25 or 50 examples and partly collapsed on 400, so LAYA’s fine-tuning is unstable at these sizes. These results rest on one seed above $n = 25$ and on a Qwen learning curve that stops at $n = 25$, and they do not show that LAYA reliably beats the generative judge.

7 DISCUSSION

What worked. Judging actions rather than inputs lets the guard use the agent’s own account of why it acts, which was the most useful input in our measurements. A judge that does not generate text adds 0.08 seconds per call, which is cheap enough to run on every call. More context was not better. Earlier turns lowered the AUC, so the default now leaves them out. We have not yet studied why.

Limitations. The main gap is missed attacks. At the default threshold the guard misses 3 of 15 held-out attacks, and ask mode does nothing about calls that are never flagged. Our evaluation sets are small (40 held-out samples, 15 of them attacks), and every interval above is wide. All samples were written by our team, and we dropped the recent turns after seeing V . Calls from public benchmarks such as InjecAgent [8] or AgentDojo [9] would be a stronger check. All our image attacks place readable text in the image. We could not run the MIPS attack (Section 3), so neither judge was tested against adversarial perturbations, which are harder to spot than visible text. LAYA’s scores are poorly calibrated on this task, so the threshold must be chosen on labeled data and changed with care. Some attack items have reasoning that reveals the injection, which inflates the effect of the reasoning, and we did not ablate the user prompt. LAYA’s window of 1,024 tokens forces us to shorten long reasoning. OpenCode’s plugin API also limited the interface. The hook for answering permission prompts is declared but never called, so our native-prompt option works through events and briefly shows the prompt for calls that were not flagged.

Attacks on the guard. We have not tested adaptive attacks on the guard itself. The reasoning that LAYA relies on most is written by the agent, so an injected instruction can also tell the agent to explain a harmful call in harmless terms. An attacker can pad a payload so that its harmful part lands in the unscored middle of a long argument, although that decision is then marked as truncated. Indirection such as variables, encoded paths or a script written in one call and run in a later one gets past the self-protection rule. An exfiltration can also be split across several calls that each look harmless. Finally, the guard runs with the user’s privileges, so a determined local process can disable it.

Security and privacy. All inference runs locally and all decisions stay on the machine. The stored log contains prompts, reasoning and tool outputs, which are sensitive in their own right, so it is deleted after 30 days by default. The fine-tuning export carries the same content.

Future work. We plan to fine-tune LAYA on decisions collected by the guard, since the export already records human corrections. These labels are biased. Missed attacks are never flagged and so never labeled, and people sometimes approve attacks, so this data needs audits and labeled attacks from other sources. We will also finish the comparison with the generative judge (a second seed for LAYA above $n = 25$ and the Qwen learning curve, which needs a way around its memory peak on long traces), add high-precision rules for well-known destructive patterns next to the model, test adaptive attacks on the guard and run the user study, starting with the planned pilot of 10 participants.

8 CONCLUSION

Secure Guard shows that a small local decision model can check every action an AI coding agent takes, at 0.08 seconds per call. In our small hand-written evaluation, the agent’s reasoning was the most useful context and earlier turns hurt. With the prompt and the reasoning, the guard caught 12 of 15 held-out attacks with one false positive in 25 benign calls. Ask mode limits the cost of false alarms, but missed attacks remain the main gap, and LAYA’s scores are poorly calibrated on this task. On visual prompt injection, LAYA fine-tuned on 200 examples matched the generative judge’s ranking with far fewer false alarms and better calibration, at an eighth of the cost per trace, but a run on 400 examples partly collapsed, so its fine-tuning is not yet reliable. The guard’s decision log can supply more training data, once its label bias is handled.

9 CONTRIBUTIONS

Tavor trained the first judge, Qwen3.5-2B fine-tuned with LoRA using PEFT, then looked for a more efficient approach and found LAYA. He integrated LAYA with the OpenCode plugin, built the scanner and dashboard and ran the evaluations. **Yahli** created the OpenCode plugin, including exporting the user’s prompt and the agent’s reasoning trace to the scanner. **Soof and Reut** created the training dataset by finding images and prompts and labeling them by hand. They also reviewed related prior research and set up the students’ academic GPU server. **Soof** also worked on a MIPS attack, which could not be completed because of hardware limitations. **Reut** also designed the user-study protocol and set up an AWS account, which was not used because the budget was no longer available.

10 LLM STATEMENT

We used several AI tools during the project: Claude (through Claude Code), Gemini and Antigravity. We did our own research and made the decisions ourselves, including the threat model, the choice of LAYA over a generative judge, the system design and the evaluation. We used AI mostly to implement code and to help with writing this report and the user-study protocol. For the code, AI agents implemented each planned task test-first, and a separate AI review pass checked it. For the evaluation, AI helped write the

scoring scripts. Claude also checked a sample of 100 automatic labels in the comparison data (Section 6.3). No person repeated that check. All numbers in this report come from our own logged runs.

What worked well. AI reviews of each task caught real defects before they shipped, including paths where a flagged tool call could still run and a security token that the dashboard page could leak. Short experiments run with the agents replaced our assumptions with measurements.

What worked less well. One plan relied on an OpenCode hook that is declared but never called, which we found only in a spike before implementation. A threshold chosen on short samples did not hold up in real use. An agent’s run that loaded several models at once froze a laptop, and after that every model run went through a memory and time watchdog. We take full responsibility for the correctness and originality of the implementation and the report.

REFERENCES

- [1] OpenCode: an open-source AI coding agent. <https://github.com/sst/opencode>, 2026.
- [2] ConvAI Innovations. LAYA: calibrated typed-decision models (laya-typed-decisions checkpoint). Model card, <https://huggingface.co/convaiinnovations/laya-typed-decisions>, 2026.
- [3] Fábio Perez and Ian Ribeiro. Ignore Previous Prompt: Attack Techniques for Language Models. NeurIPS ML Safety Workshop, 2022. arXiv:2211.09527.
- [4] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not What You’ve Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. In *AISeC ’23*, 2023.
- [5] Eugene Bagdasaryan, Tsung-Yin Hsieh, Ben Nassi, and Vitaly Shmatikov. Abusing Images and Sounds for Indirect Instruction Injection in Multi-Modal LLMs. arXiv:2307.10490, 2023.
- [6] Yichen Gong et al. FigStep: Jailbreaking Large Vision-Language Models via Typographic Visual Prompts. arXiv:2311.05608, 2023.
- [7] Xin Liu et al. MM-SafetyBench: A Benchmark for Safety Evaluation of Multimodal Large Language Models. arXiv:2311.17600, 2023.
- [8] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents. In *Findings of ACL*, 2024.
- [9] Edoardo DeBenedetti et al. AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. In *NeurIPS Datasets and Benchmarks*, 2024.
- [10] Keegan Hines et al. Defending Against Indirect Prompt Injection Attacks With Spotlighting. arXiv:2403.14720, 2024.
- [11] Eric Wallace, Kai Xiao, Reimar Leike, Lilian Weng, Johannes Heidecke, and Alex Beutel. The Instruction Hierarchy: Training LLMs to Prioritize Privileged Instructions. arXiv:2404.13208, 2024.
- [12] Sizhe Chen, Julien Piet, Chawin Sitawarin, and David Wagner. StruQ: Defending Against Prompt Injection with Structured Queries. In *USENIX Security*, 2025.
- [13] Hakan Inan et al. Llama Guard: LLM-based Input-Output Safeguard for Human-AI Conversations. arXiv:2312.06674, 2023.
- [14] Shengye Wan et al. CYBERSECEVAL 3: Advancing the Evaluation of Cybersecurity Risks and Capabilities in Large Language Models. arXiv:2408.01605, 2024.
- [15] Edoardo DeBenedetti et al. Defeating Prompt Injections by Design. arXiv:2503.18813, 2025.
- [16] Sahana Chennabasappa et al. LlamaFirewall: An Open Source Guardrail System for Building Secure AI Agents. arXiv:2505.03574, 2025.
- [17] Chuan Guo, Geoff Pleiss, Yu Sun, and Kilian Q. Weinberger. On Calibration of Modern Neural Networks. In *ICML*, 2017.
- [18] Tilmann Gneiting and Adrian E. Raftery. Strictly Proper Scoring Rules, Prediction, and Estimation. *Journal of the American Statistical Association* 102, 477 (2007), 359–378.
- [19] Luke Bailey, Euan Ong, Stuart Russell, and Scott Emmons. Image Hijacks: Adversarial Images can Control Generative Models at Runtime. In *ICML*, 2024.
- [20] Edward J. Hu et al. LoRA: Low-Rank Adaptation of Large Language Models. In *ICLR*, 2022.
- [21] Sourab Mangrulkar, Sylvain Gugger, Lysandre Debut, Younes Belkada, Sayak Paul, and Benjamin Bossan. PEFT: State-of-the-art Parameter-Efficient Fine-Tuning Methods. <https://github.com/huggingface/peft>, 2022.
- [22] Awni Hannun, Jagrit Digani, Angelos Katharopoulos, and Ronan Collobert. MLX: Efficient and Flexible Machine Learning on Apple Silicon. <https://github.com/ml-explore/mlx>, 2023.
- [23] Benjamin Warner et al. Smarter, Better, Faster, Longer: A Modern Bidirectional Encoder for Fast, Memory Efficient, and Long Context Finetuning and Inference. arXiv:2412.13663, 2024.
- [24] Ronald J. Williams. Simple Statistical Gradient-Following Algorithms for Connectionist Reinforcement Learning. *Machine Learning* 8, 3–4 (1992), 229–256.
- [25] Zhihong Shao et al. DeepSeekMath: Pushing the Limits of Mathematical Reasoning in Open Language Models. arXiv:2402.03300, 2024.
- [26] Gordon M. Becker, Morris H. DeGroot, and Jacob Marschak. Measuring Utility by a Single-Response Sequential Method. *Behavioral Science* 9, 3 (1964), 226–232.